Brendan Reed

brreed@andrew.cmu.edu

95-889 Applied Threat Analysis

Timur Snoke

Week 2: Vulnerabilities and Exploits

Boot Hole: A buffer overflow misconfiguration. Tokens exceeding internal buffer size are copied without validation. This enables an attacker with root access to execute arbitrary code before the OS loads. This execution occurs outside the scope of endpoint security tools and bypasses Secure Boot settings[1].

> **CVE:** CVE-2020-10713. CVSS Base Score of 8.2. Disclosed July 2020 by Eclypsium researchers. Affects GRUB2 versions 1.99 through 2.04 on Linux and Windows systems using UEFI Secure Boot.
>
> **Malware:** Unable to find a real-world example or instance of this vulnerability being exploited in the wild. Some teams developed a proof of concept but withheld further information to limit exposure.
>
> **Metasploit:** Because no publicly available malware exists, I was unable to find a Metasploit catalog item for this vulnerability.
>
> **Impact & Fallout:** Remediation for this vulnerability were urgently recommended fixes in GRUB2 and the boot chain. The NSA released a Cybersecurity Advisory that the vulnerability posed a risk to the majority of Linux distributions and systems running Windows 8 or later[2].

BlackLotus: The first publicly known UEFI bootkit bypassing UEFI Secure Boot in the wild. Using the exploit CVE-2022-21894, it bypasses Secure Boot and establish persistence by bringing copies of legitimate but vulnerable signed binaries to the system[3].

> **CVE:** CVE-2022-21894 ("Baton Drop"). Microsoft patches in January 2022. Proof-of-concept exploit was released in August 2022, seven months after public disclosure. CVSS Score: 4.4
>
> **Malware:** BlackLotus achieves persistence by enrolling the threat actor's Machine Owner Key (MOK) --> turns off HVCI to allow deployment of a

---

[1] Burmashev, Aleksandr, et al. "An inside Look at CVE-2020-10713, a.k.a. the Grub2 'Boothole.'" *Oracle Linux Blog*, 17 Sept. 2020, blogs.oracle.com/linux/an-inside-look-at-cve-2020-10713-aka-the-grub2-boothole.

[2] "NSA Releases Cybersecurity Advisory on Grub2 Boothole Vulnerability." *National Security Agency/Central Security Service*, 30 July 2020, www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/2294715/nsa-releases-cybersecurity-advisory-on-grub2-boothole-vulnerability/.

[3] Smolar, Martin. "Blacklotus UEFI Bootkit: Myth Confirmed." *Award-Winning News, Views, and Insight from the ESET Security Community*, 1 Mar. 2023, www.welivesecurity.com/2023/03/01/blacklotus-uefi-bootkit-myth-confirmed/.

malicious kernel driver --> leverages the kernel driver to deploy a user-mode HTTP downloader for C2 --> disables BitLocker & Microsoft Defender[4].

Metasploit: No module we could locate. PoC code is from the GitHub repository of the researcher who found the vulnerability. BlackLotus appears to be based another GitHub project, Umap.

Impact & Fallout: BlackLotus is capable of disabling OS security mechanisms such as BitLocker, HVCI, and Windows Defender. If placed into the hands of crimeware groups, it could spread quickly based on the bootkit's easy deployment. Infected devices that boot to a BlackLotus EFI binary must be completely reimaged.

Sunburst: Supply chain attack where threat actors injected the SUNBURST backdoor DLL into SolarWinds' Orion software. Distributed as a digitally-signed legitimate update to ~18,000 customers. Impacted organizations across the globe through the means of unauthenticated remote code execution.

CVE: CVE-2020-10148 (Orion auth bypass, unauthenticated RCE). SUNBURST itself does not have a dedicated CVE since it was an implant distributed via legitimate software.

Malware: SUNBURST backdoor, SUNSPOT (injects SUNBURST into Orion), TEARDROP (dropper), and RAINDROP (lateral movement loader)[5].

Metasploit: No module for SUNBURST exists. A module exists for the API authentication bypass. The campaign was a state-sponsored operation not able to be supported by Metasploit.

Impact & Fallout: Over 18,000 SolarWinds customers installed the malicious update. Malware spread undetected for approximately 14 months or more. Government departments affected included Homeland Security, State, Commerce, and Treasury. Eventual discovery by FireEye in December 2020. CISA issued mandates requiring immediate disconnection of all affected federal systems[6].

CVE-2019-19781 (Citrix ADC / NetScaler): Path traversal vulnerability in Citrix ADC. Based on improper handling of pathname in the header *NSC_USER*. Attackers

---

[4] Response, Microsoft Incident. "Guidance for Investigating Attacks Using CVE-2022-21894: The Blacklotus Campaign." *Microsoft Security Blog*, 24 June 2025, www.microsoft.com/en-us/security/blog/2023/04/11/guidance-for-investigating-attacks-using-cve-2022-21894-the-blacklotus-campaign/.

[5] "The Solarwinds Cyber-Attack: What You Need to Know." *CIS*, Center for Internet Security, 9 Nov. 2021, www.cisecurity.org/solarwinds.

[6] Michael Kerner, Sean, and Saheed Oladimeji. "Solarwinds Hack Explained: Everything You Need to Know." *TechTarget*, 3 Nov. 2023, www.techtarget.com/whatis/feature/SolarWinds-hack-explained-Everything-you-need-to-know.

could exploit it through crafted directory traversal requests to access sensitive files, and execute malicious code through crafted XML files without authentication[7].

Security Community Name: Citrix NetScaler ADC and NetScaler Gateway version 10.5. CVSS: 9.8 (Critical). Disclosed December 17, 2019.

Malware: FireEye identified and blocked attempts by a threat actor to deploy a payload named NOTROBIN. Other actors deployed cryptominers, ransomware tools, Cobalt Strike, and reverse shells[8].

Metasploit: https://github.com/rapid7/metasploit-framework/pull/12816

Impact & Fallout: At the time, over 80,000 organizations using Citrix were affected by the vulnerability. Organizations were informed that compromised systems were not guaranteed to be remediated by patching alone.

Log4Shell: An easy to exploit RCE vulnerability consisting of a malformed request. Log4j2 greatly impacts worldwide applications using Apache and security products like ElasticSearch and Logstash. Exploit attempts have led to commodity cryptominer, ransomware and other payloads[9].

CVE: CVE-2021-44228. Assigned a CVSS score of 10! Because the exploit enables full Remote Code Execution and data exfiltration. The vulnerability had existed undetected since 2013[10].

Malware: Botnets like Mirai and Kinsing used Log4Shell to propagate and install malware. Nation-state APTs, credential stealers, and cryptominers all leveraged it within days of disclosure. A successful exploit grants an attacker full control over the affected system, compromising data confidentiality, integrity, and availability.

Metasploit: *exploit/multi/http/log4shell_header_injection and auxiliary/scanner/http/log4shell_scanner*

Impact & Fallout: Research by EY showed that 93% of cloud enterprise environments were vulnerable to Log4Shell. Ten days after disclosure, only 45%

---

[7] "Detecting Citrix CVE-2019-19781 | Cisa." *CISA Cybersecurity Advisory*, 21 May 2020, www.cisa.gov/news-events/cybersecurity-advisories/aa20-031a.

[8] Narang, Satnam. "CVE-2019-19781: Critical Vulnerability in Citrix ADC and Gateway Sees Active Exploitation While Patches Are Still Not Available." *Tenable*, 24 Jan. 2020, www.tenable.com/blog/cve-2019-19781-critical-vulnerability-in-citrix-adc-and-gateway-sees-active-exploitation-while.

[9] SentinelOne. "CVE-2021-44228: Apache Log4j Vulnerability." *SentinelOne*, 24 Sept. 2025, www.sentinelone.com/blog/cve-2021-44228-staying-secure-apache-log4j-vulnerability/.

[10] Skillen, Lee. "All about Log4j/Log4shell + Mitigation (CVE-2021-44228 and Beyond)." *Cloudsmith*, 14 Feb. 2022, cloudsmith.com/blog/all-about-log4shell-mitigation-cve-2021-44228.

of workloads were patched. New exploits and malicious code families are still being found for this widespread problem[11].

CVE-2021-40444: A malicious ActiveX control can be implemented and abused by the built-in MSHTML browser engine within Microsoft Office documents. After delivering the malicious document the victim only needs to open it to trigger the exploit. This is different from built-in macro execution and only requires user interaction with the "Enable Editing" button.

MS Bulletin: https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-40444

Malware: Initial campaigns began August 2021. These distributed Beacon loaders that communicated with infrastructure associated with multiple cybercriminals. Various types of malware were delivered this way including backdoors[12].

Metasploit: Yes: https://www.rapid7.com/blog/post/2021/12/10/metasploit-wrap-up-142/

Impact & Fallout: These attacks used a MS vulnerability to access devices that gained a foothold in the network and ran privileged code from there. Still, secondary actions relied on credential theft and lateral movement to cause organization-wide impact. The vulnerability was a catalyst for the cyberattacker community to broadly move away from VBA macros toward MSHTML/ActiveX-based Office exploits.

---

[11] "Log4Shell." *Wikipedia*, Wikimedia Foundation, 23 Dec. 2025, en.wikipedia.org/wiki/Log4Shell.

[12] Intelligence, Microsoft Threat. "Analyzing Attacks That Exploit the CVE-2021-40444 MSHTML Vulnerability." *Microsoft Security Blog*, 25 June 2025, www.microsoft.com/en-us/security/blog/2021/09/15/analyzing-attacks-that-exploit-the-mshtml-cve-2021-40444-vulnerability/.